

ORBITCLEAR TECHNOLOGIES LTD

Information Security Policy

Document Reference: POL-IS-001 | Version: 3.2 | Classification: Internal — Shareable under NDA

Field	Value
Owner	Chief Information Security Officer (CISO)
Approver	Management Risk Committee
Approved	11 February 2025
Next review	February 2026
Supersedes	v3.1 (17 February 2024)
Applicable to	All OrbitClear Technologies Ltd employees, contractors, and sub-processors acting on its behalf

Contents

§	Title
1	Purpose and Scope
2	Policy Statements
3	Governance & Responsibilities
4	Risk Management
5	Human Resources Security
6	Access Control
7	Cryptography and Key Management
8	Secure Development and Change Management
9	Threat and Vulnerability Management
10	Logging, Monitoring and Incident Response
11	Physical and Environmental
12	Exceptions and Policy Violations
13	Review and Version History

1. Purpose and Scope

This Information Security Policy ("the Policy") establishes the principles and mandatory controls by which OrbitClear Technologies Ltd ("OrbitClear") protects the confidentiality, integrity and availability of its information assets and those of its customers. The Policy applies to all OrbitClear employees, contractors, and any sub-processor processing OrbitClear-controlled information on its behalf.

The Policy is aligned to ISO/IEC 27001:2022 and ISO/IEC 27002:2022, and reflects OrbitClear's obligations under the EU General Data Protection Regulation (GDPR), the EU Digital Operational Resilience Act (DORA), applicable provisions of the New York Department of Financial Services 23 NYCRR 500, and the Monetary Authority of Singapore Technology Risk Management Guidelines.

2. Policy Statements

- Information shall be classified and protected commensurate with its sensitivity, criticality and regulatory exposure.
- Access to information shall be granted on the basis of least privilege and need-to-know, subject to formal approval and periodic review.
- Customer data shall be encrypted in transit and at rest using controls approved by the Head of Security Architecture.
- Vulnerabilities in production infrastructure shall be identified and remediated within the timeframes specified in §9.
- Security incidents shall be detected, contained, eradicated and communicated in accordance with the Incident Response Plan.

3. Governance & Responsibilities

Role	Responsibility
Board Risk Committee	Oversight of cyber-risk posture; approval of risk appetite; review of major incidents.
Management Risk Committee	Policy approval and annual review; monitoring of control effectiveness through the second-line Risk Dashboard.
Chief Information Security Officer	Ownership of the Policy; definition of the Information Security Management System; reporting on cyber risk to the MRC and Board.
Head of Security Engineering	Design and operation of preventive and detective technical controls.
Head of Security Operations	24x7 monitoring, incident response, threat intelligence.
Data Protection Officer	GDPR compliance, privacy-impact assessments, liaison with supervisory authorities.
All personnel	Adherence to the Policy; completion of annual training; reporting of suspected incidents.

4. Risk Management

OrbitClear operates an Information Security Management System (ISMS) certified to ISO/IEC 27001:2022. Risk assessments shall be performed at least annually and upon material change to the service. Risks shall be logged in the Enterprise Risk Register with clear ownership, treatment plan, and residual-risk rating. Risks rated High or above require MRC endorsement for acceptance.

5. Human Resources Security

5.1 Screening

All personnel are screened prior to employment. Screening includes identity verification, right-to-work, criminal-record check (where permitted by local law), and employment-history verification for the preceding 5 years. Enhanced screening is required for roles with privileged access.

5.2 Training

All personnel complete mandatory information-security training on joining and annually thereafter. Role-specific training is provided to engineers, operations staff and customer-facing personnel.

6. Access Control

6.1 Identity Lifecycle

Access is provisioned through the joiner-mover-leaver workflow. Requests require line-manager and system-owner approval. Access for terminated personnel shall be removed within 4 business hours of HR leaver notification.

6.2 Authentication

Multi-factor authentication (MFA) is mandatory for all workforce and production user accounts, with no exception. Privileged accounts additionally require a phishing-resistant authenticator (FIDO2). Service accounts and machine identities shall use short-lived credentials issued by the approved secrets-management platform.

6.3 Privileged Access

Privileged access is granted through the approved Privileged Access Management (PAM) solution (CyberArk). Session recording shall be enabled for all privileged sessions, with a retention of 12 months. Privileged access shall be recertified quarterly by the system owner.

6.4 Access Review

Standard user access shall be recertified at least semi-annually; privileged access at least quarterly. Evidence of review shall be retained in SailPoint IdentityIQ.

7. Cryptography and Key Management

7.1 Approved Algorithms

Only cryptographic primitives on the OrbitClear Cryptographic Standard (CS-001) shall be used. At the date of this Policy the following are approved: AES-256-GCM for symmetric encryption; RSA-3072 or ECDSA P-256 (or better) for digital signature; SHA-256 or SHA-384 for hashing; TLS 1.2 (with an approved cipher suite list) or TLS 1.3 for transport.

7.2 Encryption of Data at Rest

Customer data at rest — in transactional databases, object storage, backups and archives — shall be encrypted using AES-256 envelope encryption. Encryption shall be enforced through infrastructure-as-code and validated by automated compliance tooling.

7.3 Key Management and Rotation

Data encryption keys (DEKs) and key-encryption keys (KEKs) shall be managed in a Hardware Security Module (HSM)-backed key-management service. Keys shall be rotated no less frequently than every 12 months (or immediately upon suspected compromise). Key material shall not be exportable. Access to key administration shall be restricted to named cryptographic custodians and shall require four-eyes approval.

7.4 Certificate Management

All public and private TLS certificates shall be issued through the approved certificate-management platform and renewed before expiry. Certificate expiry is monitored and alerted 30 days in advance.

8. Secure Development and Change Management

8.1 Secure SDLC

All production code shall be developed using the Secure Software Development Lifecycle (SSDLC), including threat modelling for material new services, static and dynamic application security testing, software composition analysis, and peer review. No developer may merge to the protected branch without peer approval.

8.2 Change Management

All production changes shall be approved through the Change Advisory Board workflow. Emergency changes require post-implementation review within 5 business days. Direct production changes are prohibited.

9. Threat and Vulnerability Management

9.1 Scanning

Production infrastructure shall be continuously scanned for vulnerabilities by the approved vulnerability-management platform. Container images shall be scanned on every build and blocked at CI on critical findings. Externally exposed assets shall additionally be subject to monthly authenticated scans.

9.2 Threat Intelligence

OrbitClear subscribes to commercial and open-source threat intelligence feeds and participates in the Financial Services Information Sharing and Analysis Centre (FS-ISAC).

9.3 Penetration Testing

An annual third-party penetration test of the customer-facing application shall be commissioned. A red-team exercise shall be performed at least every two years. Findings shall be tracked to closure.

9.4 Remediation Service-Level Agreements

Vulnerabilities shall be remediated within the following service-level agreements, measured from the date the vulnerability is first detected by OrbitClear's scanning or notified by a third party:

Severity (CVSS v3.1)	Remediation SLA
Critical (CVSS 9.0–10.0)	14 calendar days
High (CVSS 7.0–8.9)	30 calendar days
Medium (CVSS 4.0–6.9)	60 calendar days
Low (CVSS 0.1–3.9)	90 calendar days

Exceptions to the SLA require written CISO approval and must be logged in the Risk Register with an agreed remediation date and compensating controls.

10. Logging, Monitoring and Incident Response

10.1 Logging

Security-relevant events (authentication, authorisation, privileged actions, configuration changes) shall be logged, shipped to the central SIEM (Splunk Cloud, EU region) and retained for at least 18 months on-line and 7 years in long-term archive.

10.2 Monitoring

The Security Operations Centre operates 24x7 and monitors for events mapped to MITRE ATT&CK tactics. Detections are reviewed quarterly.

10.3 Incident Response

Incidents are managed per the Incident Response Plan (POL-IR-001). Material incidents are reported to affected customers within 24 hours of confirmation and, where required, to supervisory authorities within the applicable statutory time-frame (GDPR Art 33: 72 hours; DORA major-incident reporting thresholds).

11. Physical and Environmental

OrbitClear does not operate its own data centres; physical controls are provided by the infrastructure subservice organisation (AWS), attested under SOC 2 Type 2 and ISO 27001, and are relied upon as Complementary Subservice Organization Controls. OrbitClear corporate offices enforce badge access, visitor management and CCTV.

12. Exceptions and Policy Violations

Policy exceptions require a risk-based assessment and CISO approval, and shall be time-bound with an agreed remediation plan. Wilful violations of this Policy may result in disciplinary action up to and including termination of employment or contract.

13. Review and Version History

Version	Date	Author	Summary
3.2	11 Feb 2025	CISO Office	Alignment to ISO 27002:2022 controls catalogue; addition of §7.1 approved algorithms list; clarification of SLA table in §9.4.
3.1	17 Feb 2024	CISO Office	Annual review; addition of DORA references; updated training cadence.
3.0	05 Mar 2023	CISO Office	Major rewrite for ISO 27001:2022 transition.